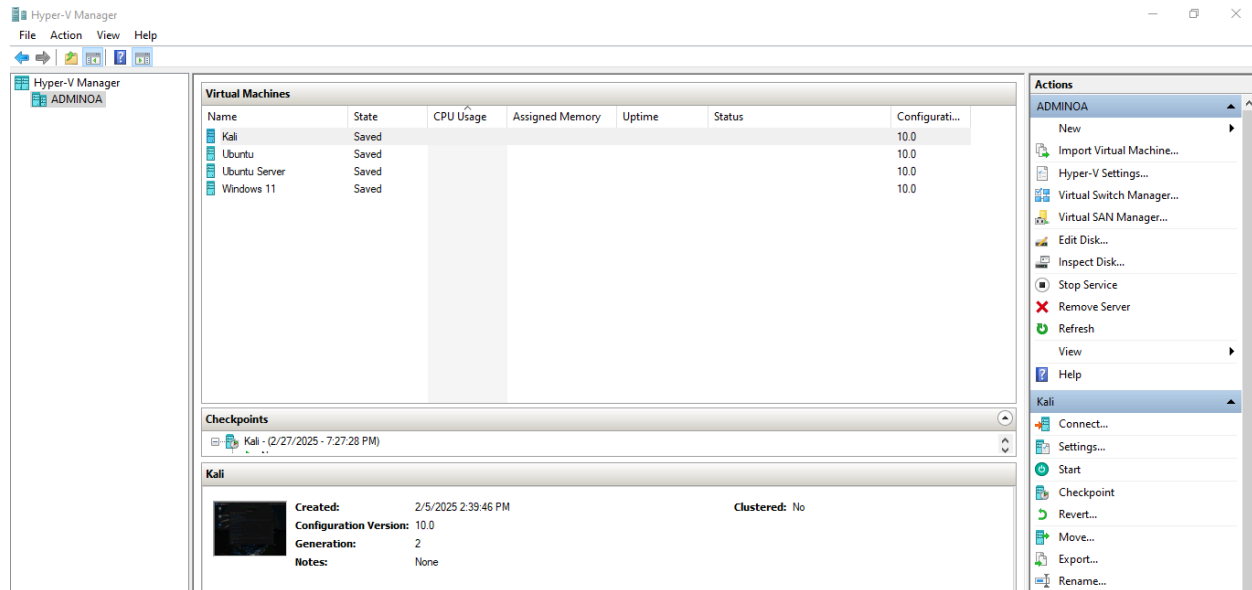


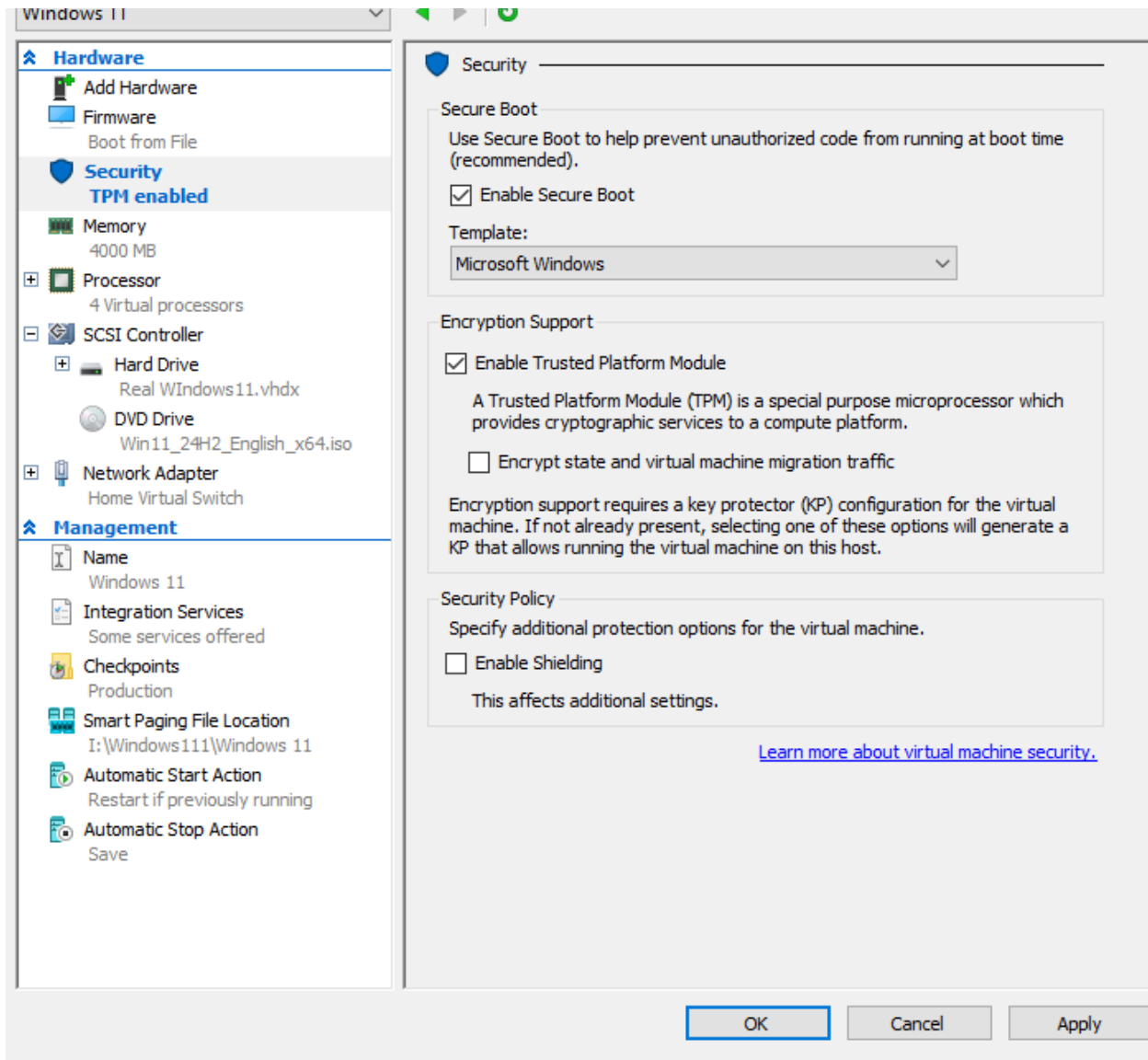
Operating system hardening is the process of taking precautions to make sure an operating system has as few weaknesses as feasible that could be exploited. The steps below apply to both **Windows** and **Linux** systems.

Virtual Machine Setup

On our system of 4 running Virtual Machines each running a different operating system.



Before launching any VM, it is important to make sure secure boot is enabled.

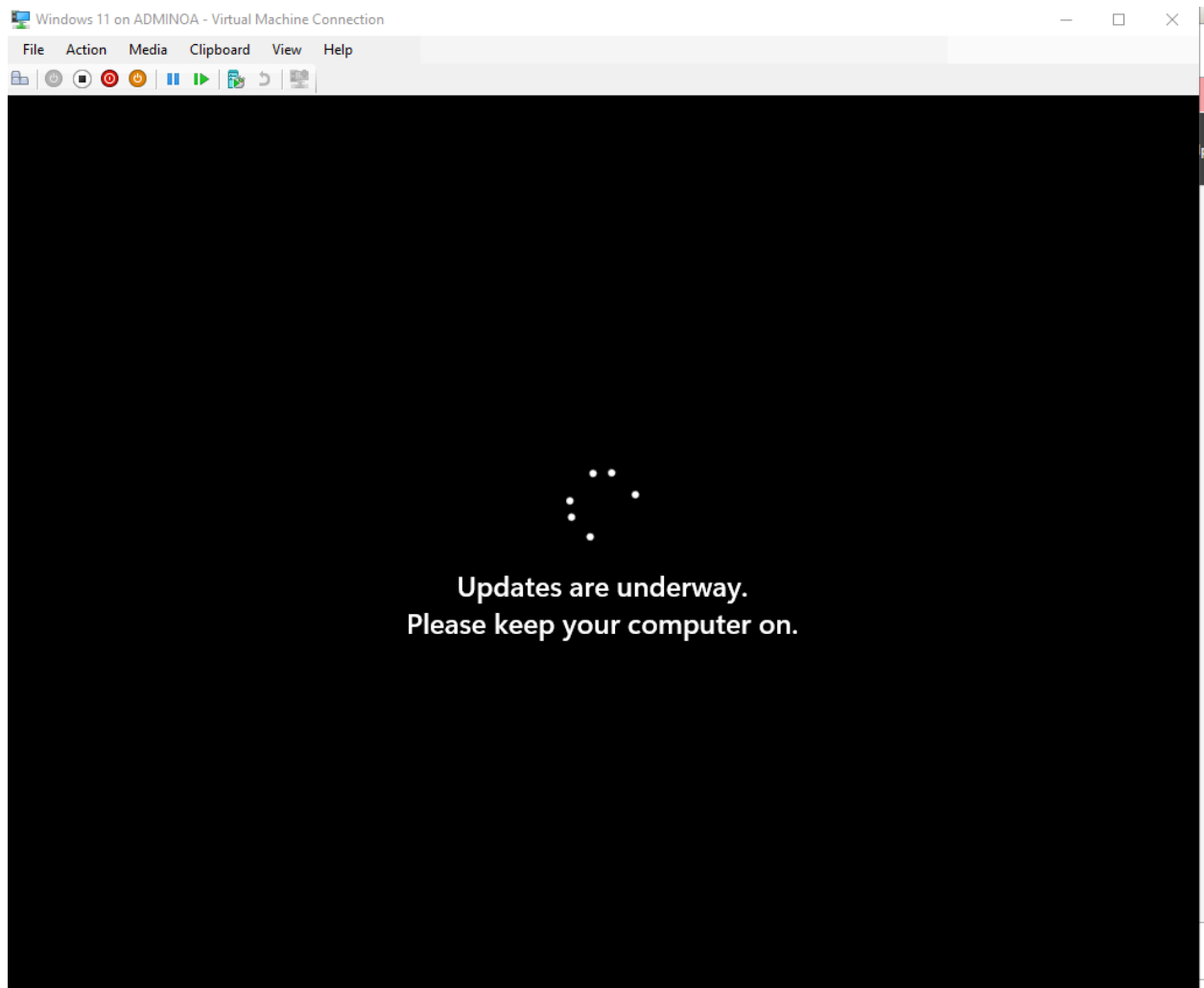


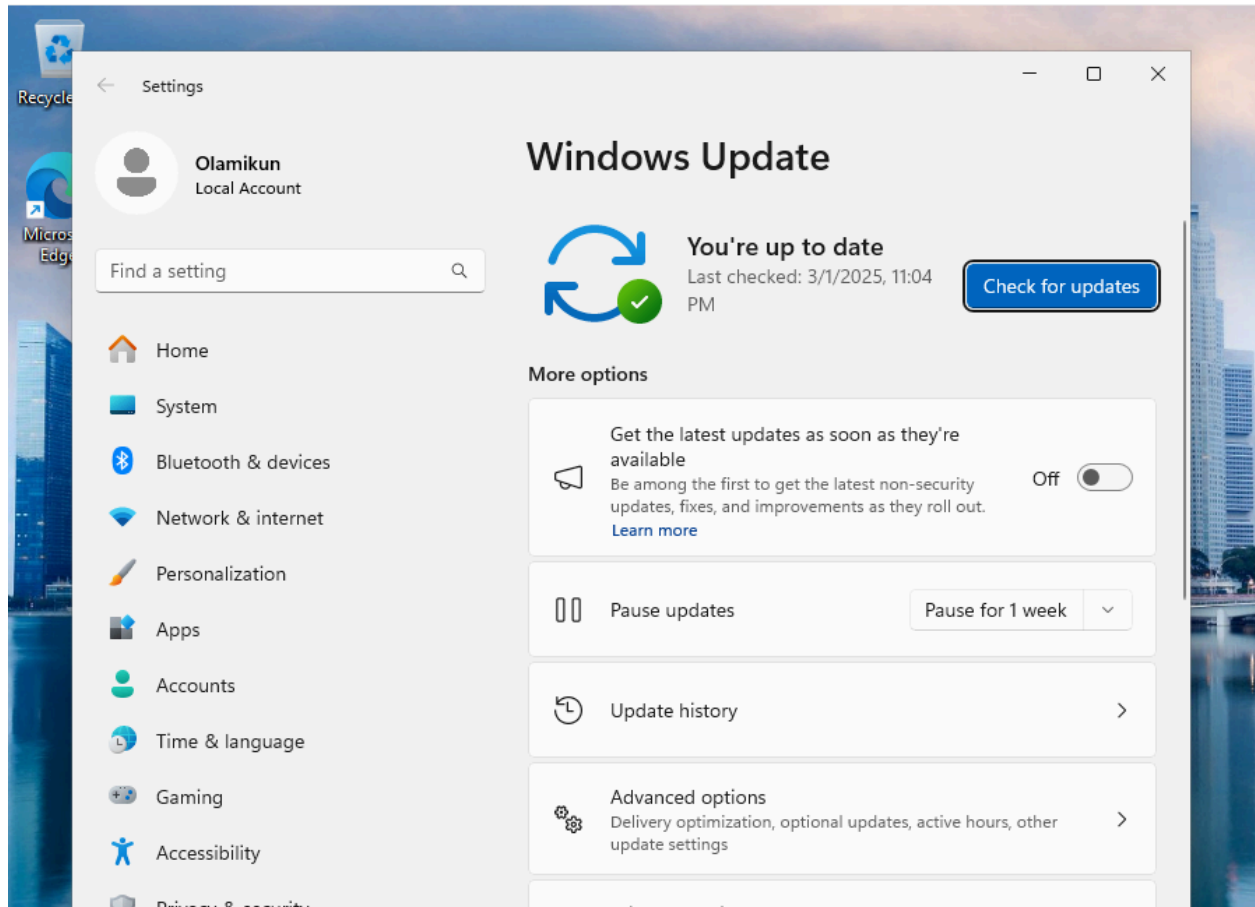
We are able to guarantee that the software boots only with a user with recognized authority.

Hardening in VM

After booting up the virtual machine, the most crucial hardening technique is making sure

software is updated to its latest version for the utmost security.





Securing VM's on Host Machine

Once your VM's are up and running, it is important to set the rules and conditions on a Host Machine.

The host machine can control aspects like Password Policy, Access Controls, and Viewable files on specific roles.

Password Policy

A crucial step in System hardening is using a strong password policy system that every user on a server must follow.

Password Settings

Directly Applies To

Name: *

Precedence: *

☒ Enforce minimum password length
Minimum password length (characters): * 7

☒ Enforce password history
Number of passwords remembered: * 24

☒ Password must meet complexity requirements

☐ Store password using reversible encryption

☒ Protect from accidental deletion

Description:

Password age options:

☒ Enforce minimum password age
User cannot change the password withi... * 1

☒ Enforce maximum password age
User must change the password after (... * 42

☒ Enforce account lockout policy:
Number of failed logon attempts allowed: * 5
Reset failed logon attempts count after (m... * 30
Account will be locked out
☒ For a duration of (mins): * 30
☐ Until an administrator manually unlocks the account

Directly Applies To

Name	Mail

Add...
Remove

More Information

OK Cancel

Criteria can be set for minimum required password lengths, how long a password is remembered, and how many times a user can get the password incorrect before the system locks them out. Different password requirements and rules can be set for different branches in an organization.

New Object - User

Create in: ServerOA.local/Users

When you click Finish, the following object will be created:

Full name: Test ing

User logon name: Testing@ServerOA.local

The user must change the password at next logon.

< Back Finish Cancel

The next time this user logs in they will be prompted to change their password upon entry.

CustomerServ 1 Properties

Member Of	Dial-in	Environment	Sessions
Remote control	Remote Desktop Services Profile		COM+
General	Address	Account	Profile
		Telephones	Organization

User logon name:

User logon name (pre-Windows 2000):

☐ Unlock account

Account options:

- ☒ User must change password at next logon
- ☐ User cannot change password
- ☐ Password never expires
- ☐ Store password using reversible encryption

Account expires

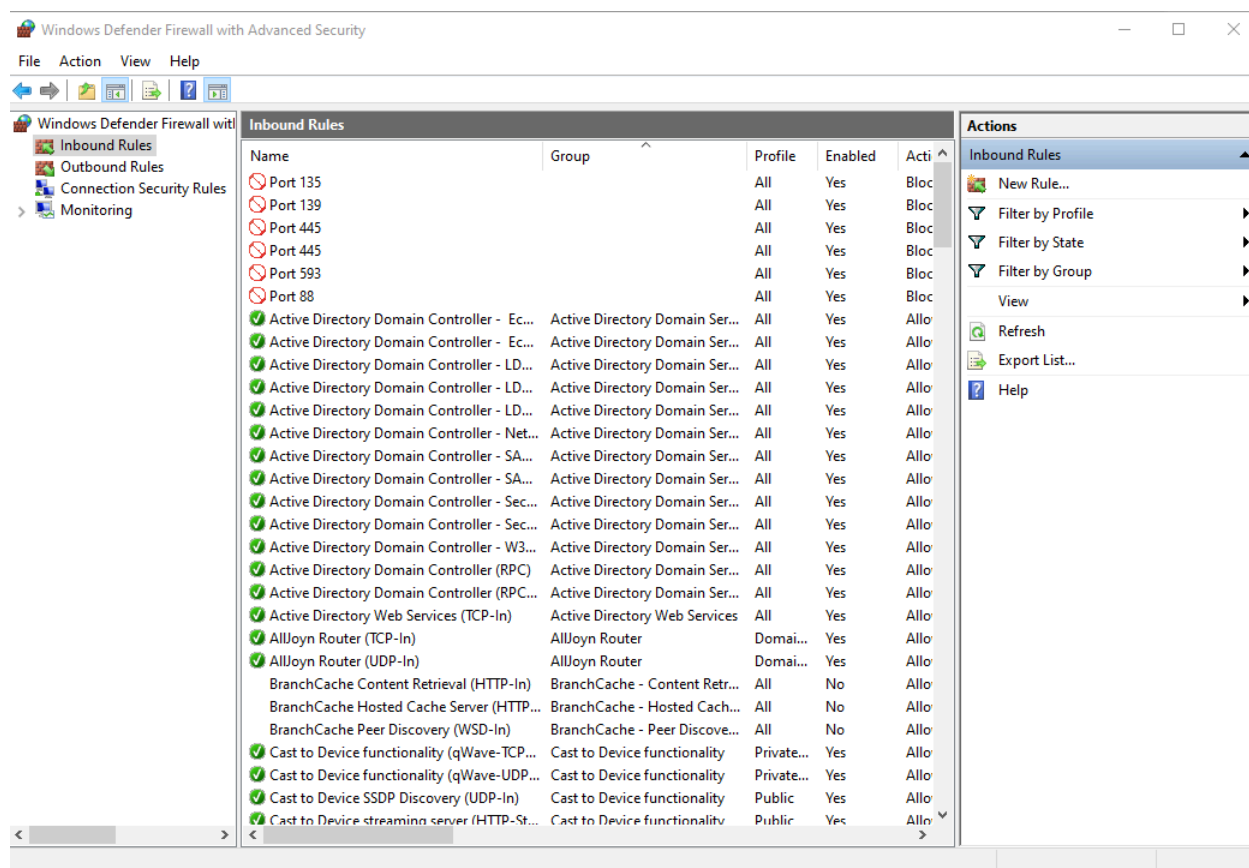
☒ Never

☐ End of:

Further rules can be set for individual users within a branch. For example you are able to prevent certain users from even changing their passwords.

Hardening Using Firewall

Another Important Technique is using a firewall to prevent certain features on a Operating System from being used.



As we can see, Port 135 indicates that a network scan will not reveal the port. Because unused ports are susceptible to being connected to and utilized to compromise systems, it is crucial to spend time configuring inbound rules to disable them.

Assessment and Testing

Using Nessus we are able to scan our network and see if there is any vulnerabilities to our network setup, It is a test to see how well our hardening process was.

The screenshot shows the Tenable Nessus Essentials interface. The main panel displays a list of 20 vulnerabilities. All vulnerabilities are categorized as 'Info' (Informational). The table includes columns for Severity, CVSS, VPR, EPSS, Name, Family, and Count.

Sev	CVSS	VPR	EPSS	Name	Family	Count
INFO	...	...	...	SMB (Multiple Issues)	Windows	7
INFO	...	...	...	Microsoft Windows (Multiple Issues)	Windows	2
INFO	...	...	...	DCE Services Enumeration	Windows	12
INFO	...	...	...	DNS Server Detection	DNS	2
INFO	...	...	...	LDAP Crafted Search Request Server Information Disclosure	Misc.	2
INFO	...	...	...	LDAP Server Detection	Service detection	2
INFO	...	...	...	Common Platform Enumeration (CPE)	General	1
INFO	...	...	...	Device Type	General	1
INFO	...	...	...	Host Fully Qualified Domain Name (FQDN) Resolution	General	1
INFO	...	...	...	Kerberos Information Disclosure	Misc.	1
INFO	...	...	...	Nessus Scan Information	Settings	1
INFO	...	...	...	Nessus Windows Scan Not Performed with Admin Privileges	Settings	1
INFO	...	...	...	Network Time Protocol (NTP) Server Detection	Service detection	1
INFO	...	...	...	OS Fingerprints Detected	General	1
INFO	...	...	...	OS Identification	General	1
INFO	...	...	...	OS Identification and Installed Software Enumeration over SSH v2 (Using New SSH Library)	Misc.	1
INFO	...	...	...	OS Security Patch Assessment Not Available	Settings	1
INFO	...	...	...	Ping the remote host	Port scanners	1

On the right, the 'Host Details' section shows IP: 192.168.56.1, DNS: AdminQA-ServerQA.local, OS: Windows, and a 'Vulnerabilities' donut chart showing 100% Info level findings.

There were no vulnerabilities in the first initial scan.

The screenshot shows the 'Active Directory Scan' page in Tenable Nessus Essentials. It displays a table of scan history with one entry: 'Current' scan completed today at 12:59 PM.

Start Time	Last Scanned	Status
Current Today at 12:59 PM	Today at 12:59 PM	Completed

The 'Scan Details' section on the right provides information about the scan: Policy: Active Directory Starter Scan, Status: Completed, Severity Base: CVSS v3.0, Scanner: Local Scanner, and Elapsed time: a few seconds.

Another scan of the Active Directory.

Basic Network Scan / 192.168.56.1

Vulnerabilities 31

Sev	CVSS	VPR	EPSS	Name	Family	Count
MIXED				SSL (Multiple Issues)	General	4
INFO				SMB (Multiple Issues)	Windows	7
INFO				HTTP (Multiple Issues)	Web Servers	6
INFO				Microsoft Windows (Multiple Issues)	Windows	2
INFO				TLS (Multiple Issues)	Service detection	2
INFO				Netstat Portscanner (SSH)	Port scanners	1024
INFO				DCE Services Enumeration	Windows	12
INFO				Service Detection	Service detection	8
INFO				LDAP Crafted Search Request Server Information Disclosure	Misc.	2
INFO				LDAP Server Detection	Service detection	2
INFO				Additional DNS Hostnames	General	1
INFO				COM+ Internet Services (CIS) Server Detection	Windows	1
INFO				Common Platform Enumeration (CPE)	General	1
INFO				Device Type	General	1
INFO				DNS Server Detection	DNS	1

Host Details

IP: 192.168.56.1
 DNS: AdminQA-Server0A.local
 OS: Microsoft Windows
 Start: Today at 1:02 PM
 End: Today at 1:11 PM
 Elapsed: 8 minutes
 KB: [Download](#)

Vulnerabilities

Donut Chart Legend: Critical (Red), High (Orange), Medium (Yellow), Low (Green), Info (Blue)

The final network scan gave 1 mixed notification,

Vulnerabilities 31

MEDIUM SSL Certificate Cannot Be Trusted

Description

The server's X.509 certificate cannot be trusted. This situation can occur in three different ways, in which the chain of trust can be broken, as stated below:

- First, the top of the certificate chain sent by the server might not be descended from a known public certificate authority. This can occur either when the top of the chain is an unrecognized, self-signed certificate, or when intermediate certificates are missing that would connect the top of the certificate chain to a known public certificate authority.
- Second, the certificate chain may contain a certificate that is not valid at the time of the scan. This can occur either when the scan occurs before one of the certificate's 'notBefore' dates, or after one of the certificate's 'notAfter' dates.
- Third, the certificate chain may contain a signature that either didn't match the certificate's information or could not be verified. Bad signatures can be fixed by getting the certificate with the bad signature to be re-signed by its issuer. Signatures that could not be verified are the result of the certificate's issuer using a signing algorithm that Nessus either does not support or does not recognize.

If the remote host is a public host in production, any break in the chain makes it more difficult for users to verify the authenticity and identity of the web server. This could make it easier to carry out man-in-the-middle attacks against the remote host.

Solution

Purchase or generate a proper SSL certificate for this service.

See Also

<https://www.itu.int/rec/T-REC-X.509/en>
<https://en.wikipedia.org/wiki/X.509>

Output

```

The following certificate was at the top of the certificate
chain sent by the remote host, but it is signed by an unknown
certificate authority :

|-Subject : O=Reasus Users United/OU=Reasus Server/L=New York/C=US/ST=NY/CN=AdminQA
|-Issuer : O=Reasus Users United/OU=Reasus Certification Authority/L=New York/C=US/ST=NY/CN=Reasus Certification Authority
  
```

To see debug logs, please visit individual host

Plugin Details

Severity: Medium
 ID: 51192
 Version: 1.19
 Type: remote
 Family: General
 Published: December 15, 2010
 Modified: April 27, 2020

Risk Information

Risk Factor: Medium
CVSS v3.0 Base Score: 6.5
 CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:U/A:N
 CVSS v2.0 Base Score: 6.4
 CVSS v2.0 Vector: CVSS2#AV:N/AC:L/AU:N/C:P/I:P/A:N

It was because of our SSL Certificate not being given from a trustworthy source. Outside of this notification our systems were perfectly secure, no unnecessary ports open or detected on our system.